

06a — HTTPS

Key Concepts

- **HTTPS** — HTTP + TLS encryption; all data in transit is encrypted
 - **TLS (Transport Layer Security)** — the encryption protocol underneath HTTPS
 - **SSL** — old name for TLS; deprecated but name persists (SSL/TLS used interchangeably)
 - **Certificate** — file the server sends to prove its identity
 - **Certificate Authority (CA)** — trusted third party that signs and vouches for certificates (e.g., DigiCert, Let's Encrypt)
 - **Man-in-the-middle attack** — attacker intercepts plain HTTP traffic and reads/modifies it
-

How It Works

1. Browser connects to server and requests secure connection
 2. Server sends TLS certificate (contains public key)
 3. Browser verifies certificate against trusted CA
 4. TLS handshake — both sides negotiate a shared session key
 5. All further communication encrypted with that session key
-

What the Padlock Means

- Certificate is valid and CA-verified
 - Connection is encrypted
 - You're talking to the real server (not an impersonator)
-

Industry Examples

- **Google** — marks all HTTP sites as "Not Secure" in Chrome since 2018
 - **Let's Encrypt** — free CA; automated HTTPS adoption across millions of sites
 - **Every major site** — Google, Amazon, Facebook — HTTPS only
-

Interview Questions

Q: What is HTTPS and why should every API use it?

HTTPS is HTTP over TLS encryption. Without it, anyone on the network can read traffic in plain text (man-in-the-middle attack). With it, all data is encrypted in transit and the server's identity is verified via certificate.

Q: What is the difference between HTTPS, TLS, and SSL?

HTTPS is the application protocol (HTTP running over TLS). TLS is the encryption protocol that handles both identity verification (via certificate) and data encryption. SSL is the deprecated predecessor to TLS — the name persists but TLS is what's actually used.

Q: What does a TLS certificate prove?

That the server is who it claims to be — verified by a trusted Certificate Authority. Prevents impersonation attacks.